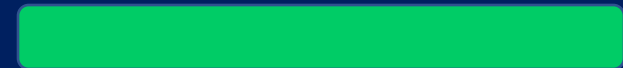
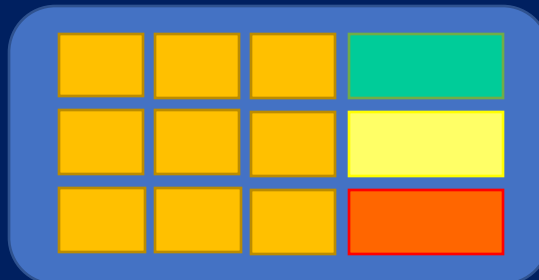




DefCamp[#]9
Where Hacking & Security Collide

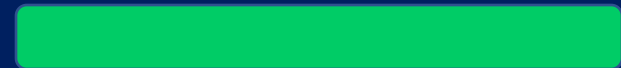
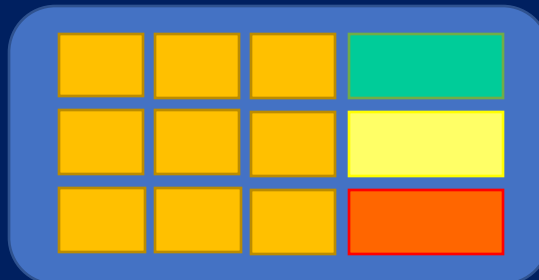
Implementation of Information Security Techniques on Modern Android Based Kiosk ATM/Remittance Machines

Muhammad Mudassar Yamin



About Me

- Research Fellow @NTNU
- PhD-Candidate | L|PT-MASTER | OSCP | C|EH | C)PTE | C|HFI | C)ISSO | C|BP | CCNA-Cyber ops
- 50+ Security Researcher Acknowledgments
- Interpol Innovation Medalist



Introduction

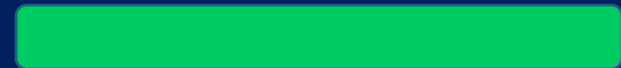
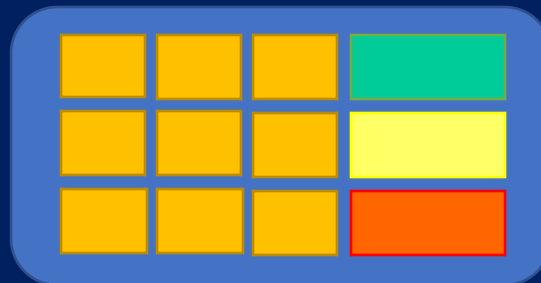
Background

Problem

Impact

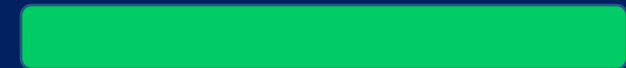
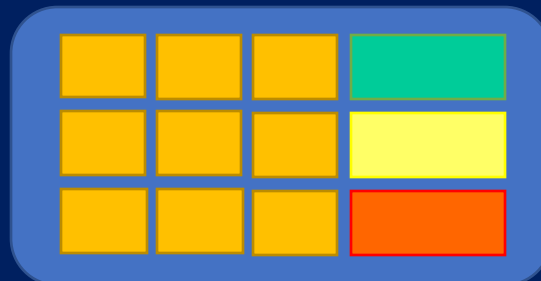
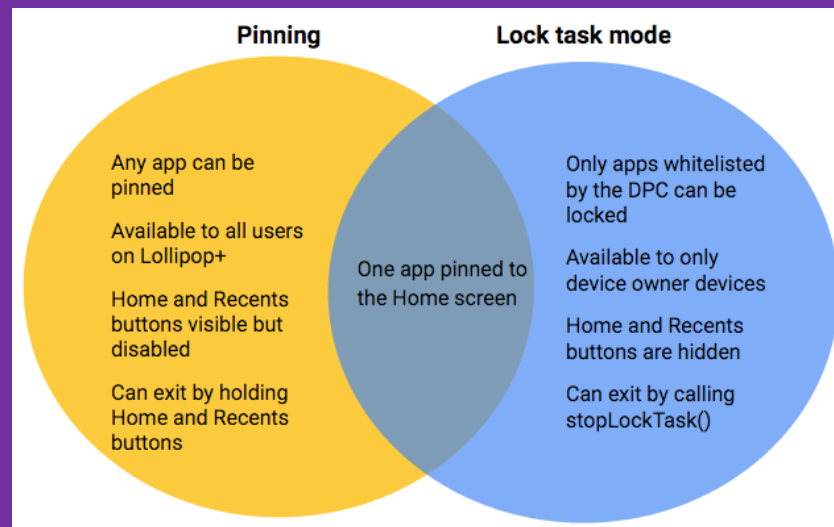
Solution

Future



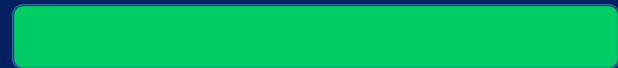
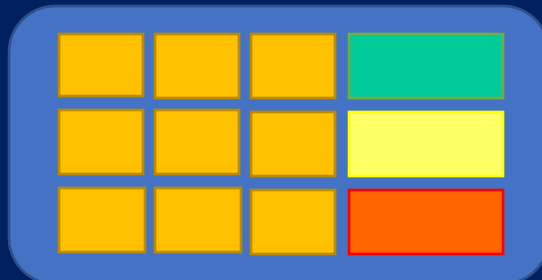
Introduction

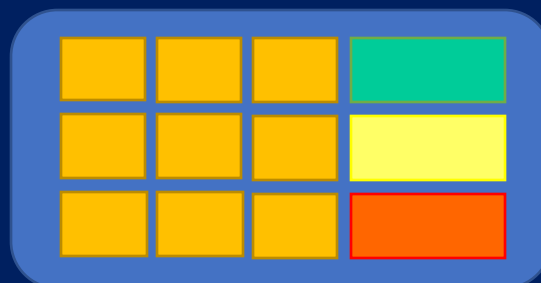
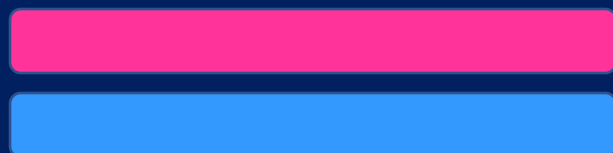
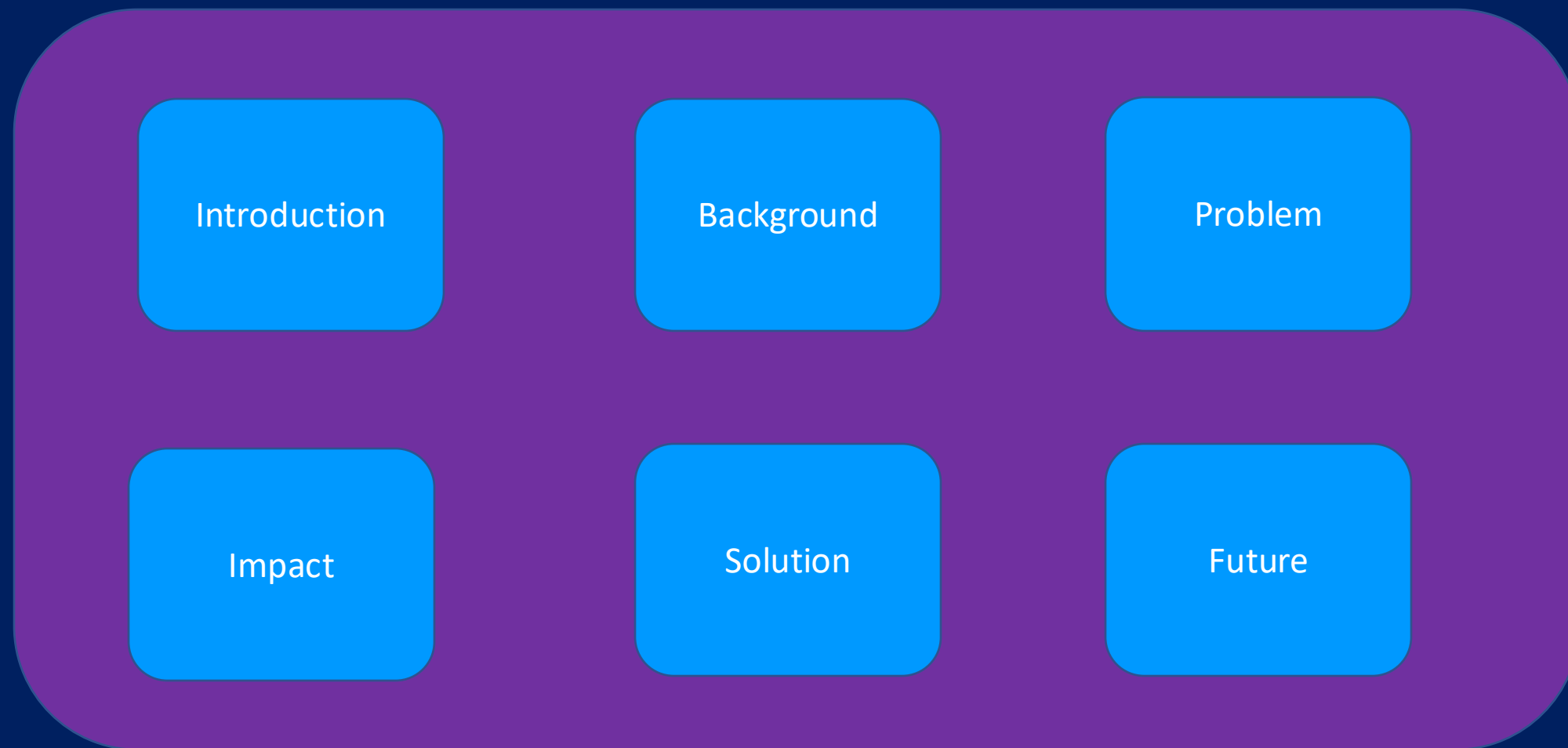
Android 5.0 Lollipop introduced two new ways to configure Android devices for a single purpose app pinning and lock task mode



Introduction

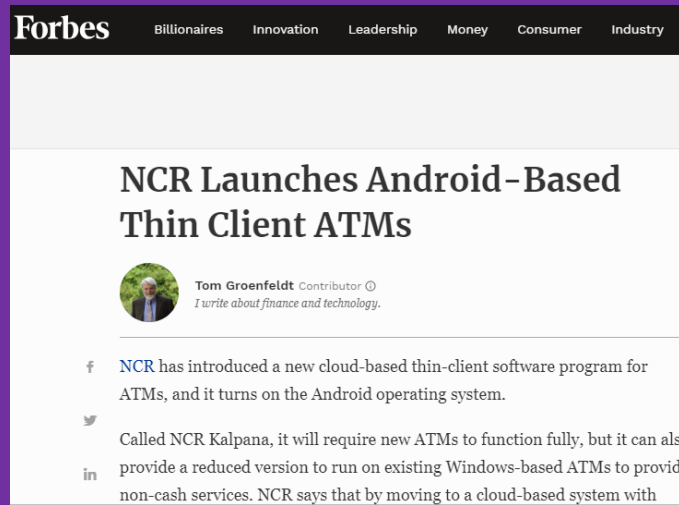
This enabled Android devices to be used for a single purpose, such as digital signage, ticket printing, point of sale, or inventory management



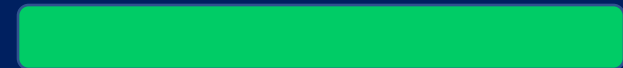
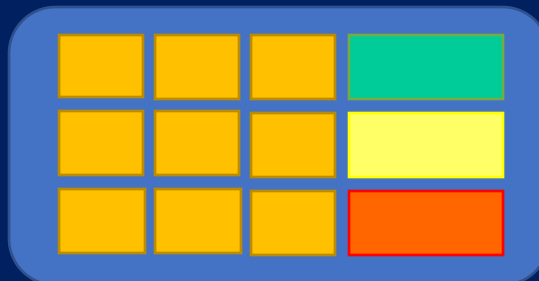


Background

- Support for Windows XP ended April 8, 2014
- Ninety-five percent of the world's ATMs are running on Windows XP at that time, and the industry was forced to move to Windows 7

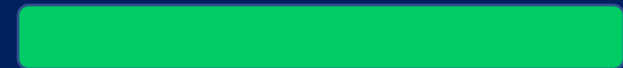
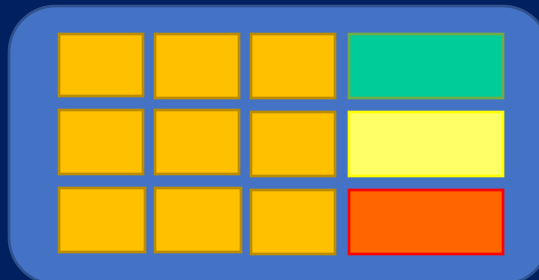


<https://www.forbes.com/sites/tomgroenfeldt/2015/04/08/ncr-launches-android-based-thin-client-atms/#7af5a83b70b3>

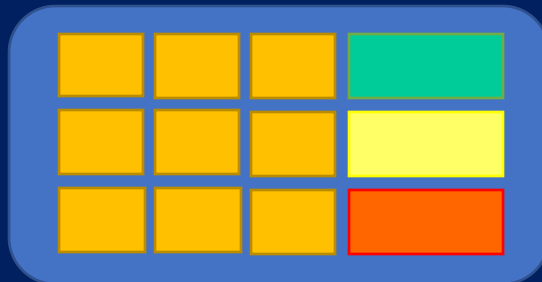


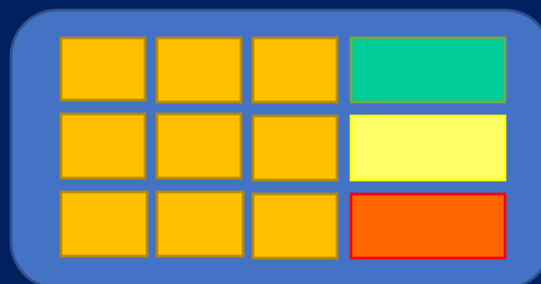
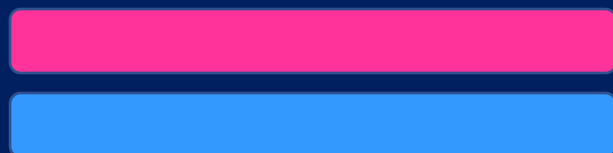
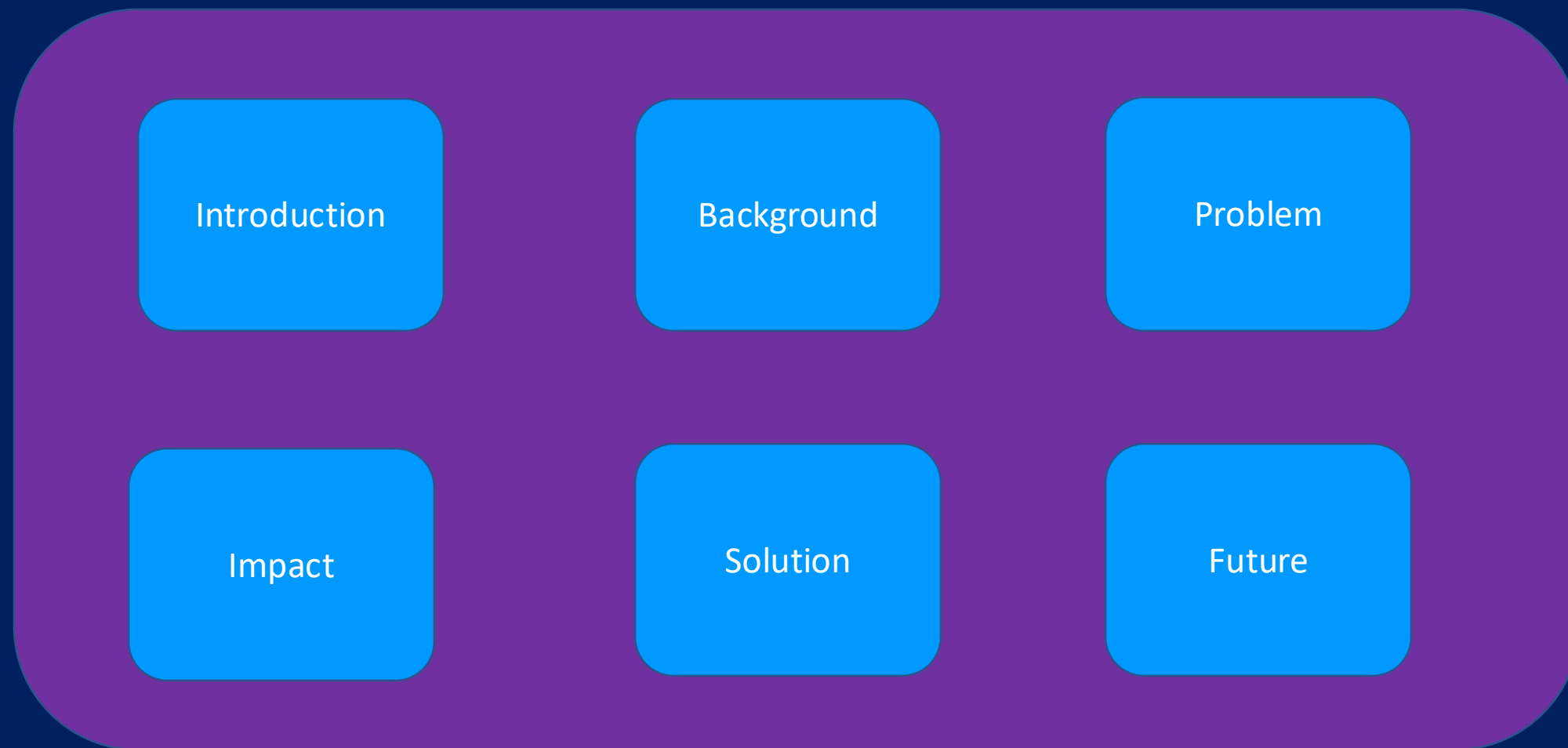
Background

- Free Android Operating System
- ATM operating costs reduction by 27 to 40%
- No threat of traditional Malwares
- ATM owners typically replace their ATMs every three to four years, next time they will replace it with ATM that would probably be running android



What Could Possibly Go Wrong?

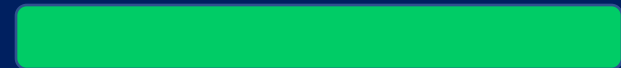
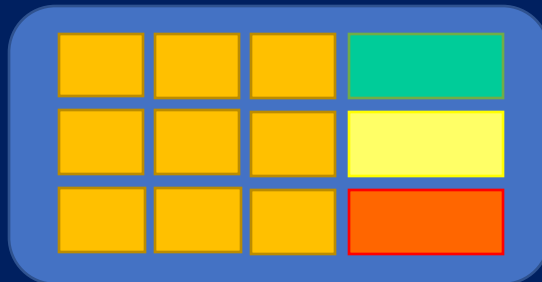


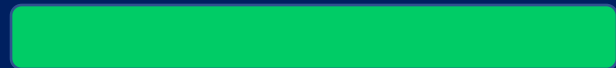
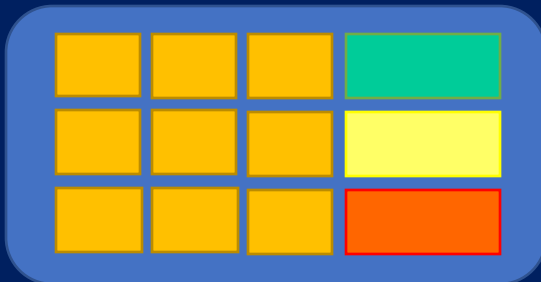
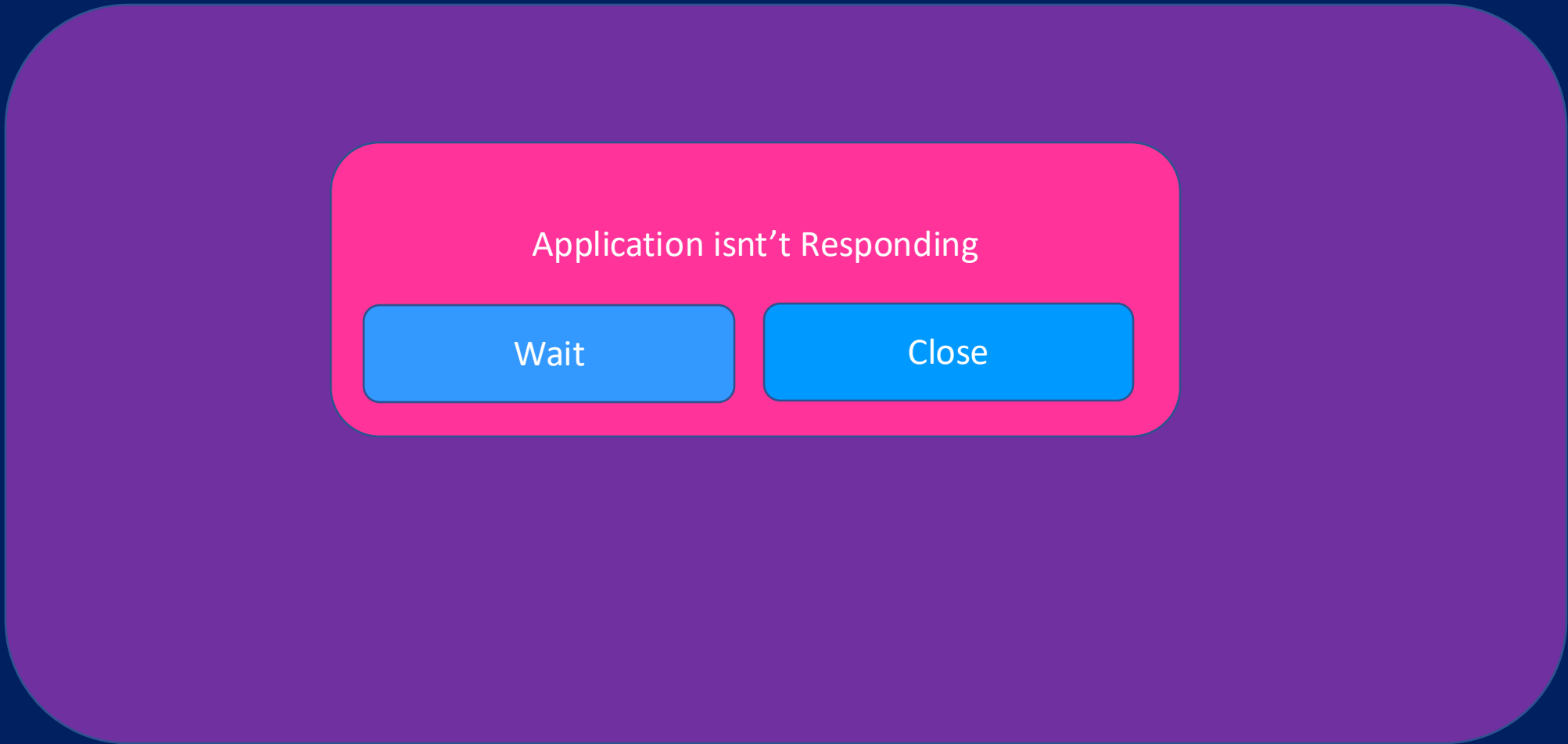


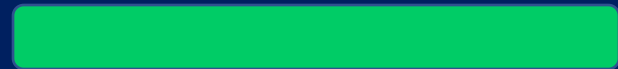
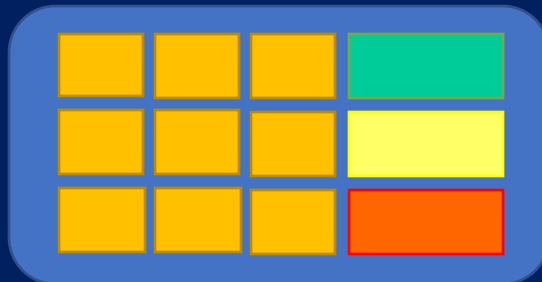
Problem

- ANRs when the UI thread of an Android app is blocked for too long, an "Application Not Responding" (ANR) error is triggered. If the app is in the foreground, the system displays a dialog to the user. The ANR dialog gives the user the opportunity to force quit the app

<https://developer.android.com/topic/performance/vitals/anr>







Introduction

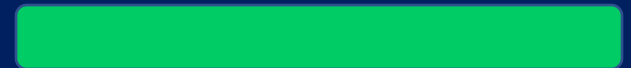
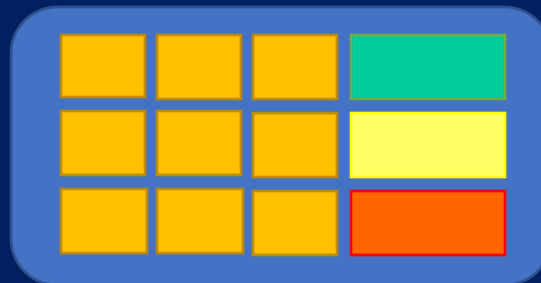
Background

Problem

Impact

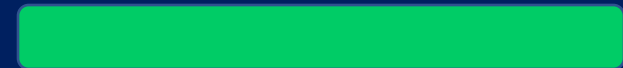
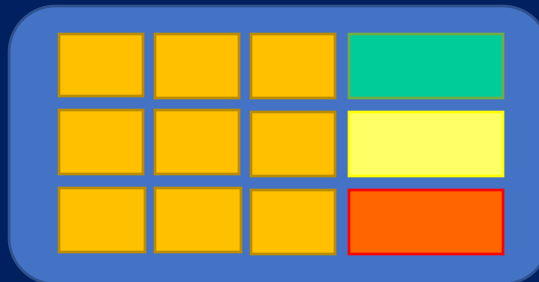
Solution

Future

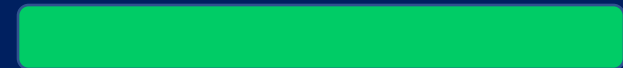
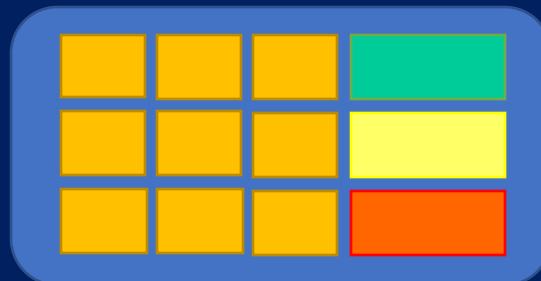
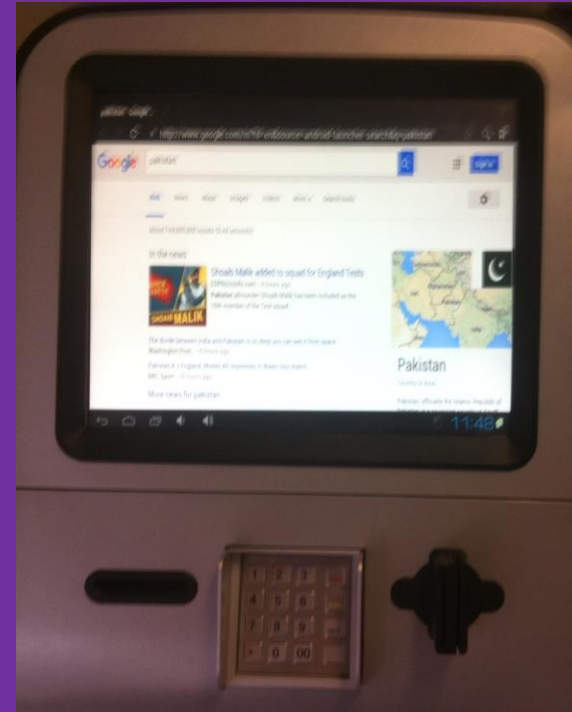


Impact

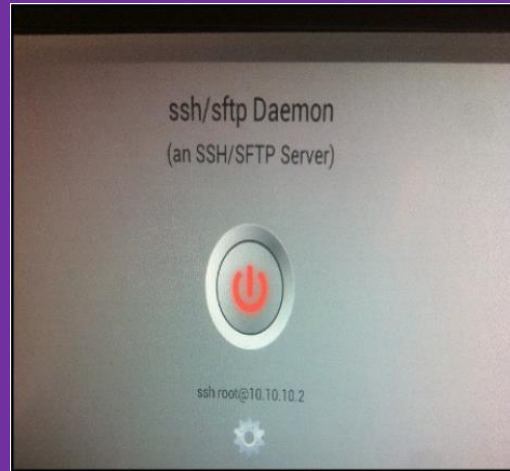
- Android OS Access
- Malware upload
- Network Traffic Monitoring
- Source Code theft



Android OS Access



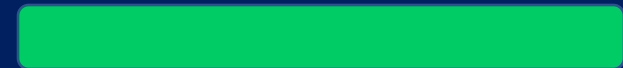
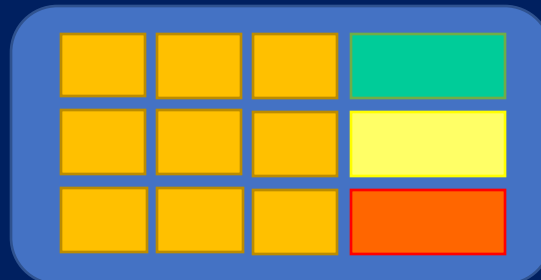
Malware upload



10.10.10.2 - PuTTY

```
1|root@android:/sdcard # cd /data/data
root@android:/data/data # ls
com.MyGica.AppleTV
com.amlogic.OOBE
com.amlogic.PicturePlayer
com.amlogic.inputmethod.remote
com.amlogic.netfilebrowser
com.android.backupconfirm
com.android.bluetooth
com.android.browser
com.android.calculator2
com.android.calendar
com.android.camera
com.android.certinstaller
```

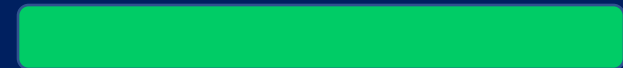
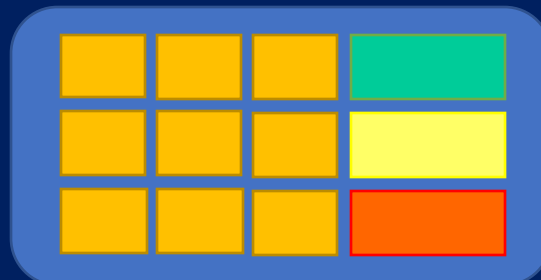
```
10-06 11:03:46|REQUEST = Card Number SOURCE : 433 Account Number SOURCE : Amount : 563289 NAME TARGET : ANK
ET : 32
10-06 11:03:46|RESPONSE > {"source_account_balance":"15000000","result_code":1,"response":"Success","message":"Success Response"}
10-06 11:04:50|REQUEST = Card Number SOURCE : 433 Account Number SOURCE : 422 Amount : 5555 CNIC TARGET : 8652
10-06 11:04:50|RESPONSE > {"source_account_balance":"15000000","result_code":1,"response":"Success","message":"Success Response"}
10-06 11:06:10|REQUEST = Card Number SOURCE : 433 Account Number SOURCE : 422 Amount : 5555 CNIC TARGET : 445
10-06 11:06:10|RESPONSE > {"source_account_balance":"15000000","result_code":1,"response":"Success","message":"Success Response"}
10-06 11:08:40|REQUEST = Card Number SOURCE : Reading433 Account Number SOURCE : 422 Amount : 5556 NAME TARGET :
nt Number TARGET : 5658
10-06 11:08:40|RESPONSE > {"source_account_balance":"15000000","result_code":1,"response":"Success","message":"Success Response"}
10-06 12:32:06|REQUEST = Card Number SOURCE : 433 Account Number SOURCE : 422 Amount : 895 NAME TARGET :
er TARGET : 5624566
numbe
```



Network Traffic Monitoring

The screenshot displays a network traffic monitoring application with the following components:

- Top Bar:** Contains three tabs: "Intercept" (highlighted in orange), "History", and "Options".
- Request Information:** Shows a lock icon and the text "Request to https://[redacted]".
- Action Buttons:** A row of four buttons: "Forward", "Drop", "Intercept is on", and "Action".
- View Options:** A row of four buttons: "Raw", "Params", "Headers", and "Hex".
- Request Details:**
 - Method and URL: `POST /kiosk_remittance/index.php/api/transaction/PerformRemitTransactionbyCNIC? HTTP/1.1`
 - Content-Length: `118`
 - Content-Type: `application/x-www-form-urlencoded`
 - Host: `[redacted]`
 - Connection: `Keep-Alive`
 - User-Agent: `Apache-HttpClient/UNAVAILABLE (java 1.4)`
 - Query String: `card_number_source=5300[redacted]&account_number_source=422[redacted]&amount=528[redacted]&cnic_target=12[redacted]`



Source Code theft

```
package com.bixolon.printer.utility;

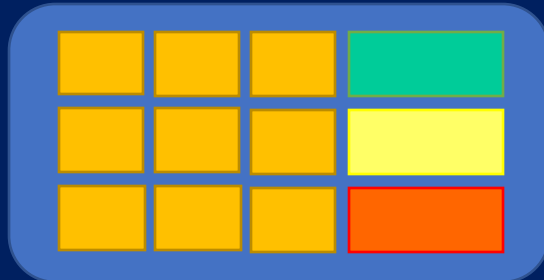
import java.security.InvalidKeyException;

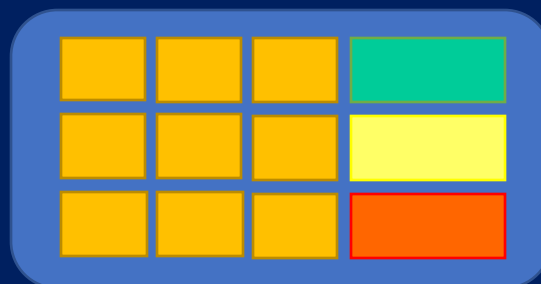
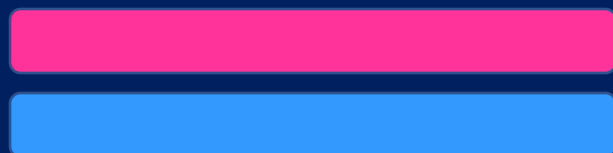
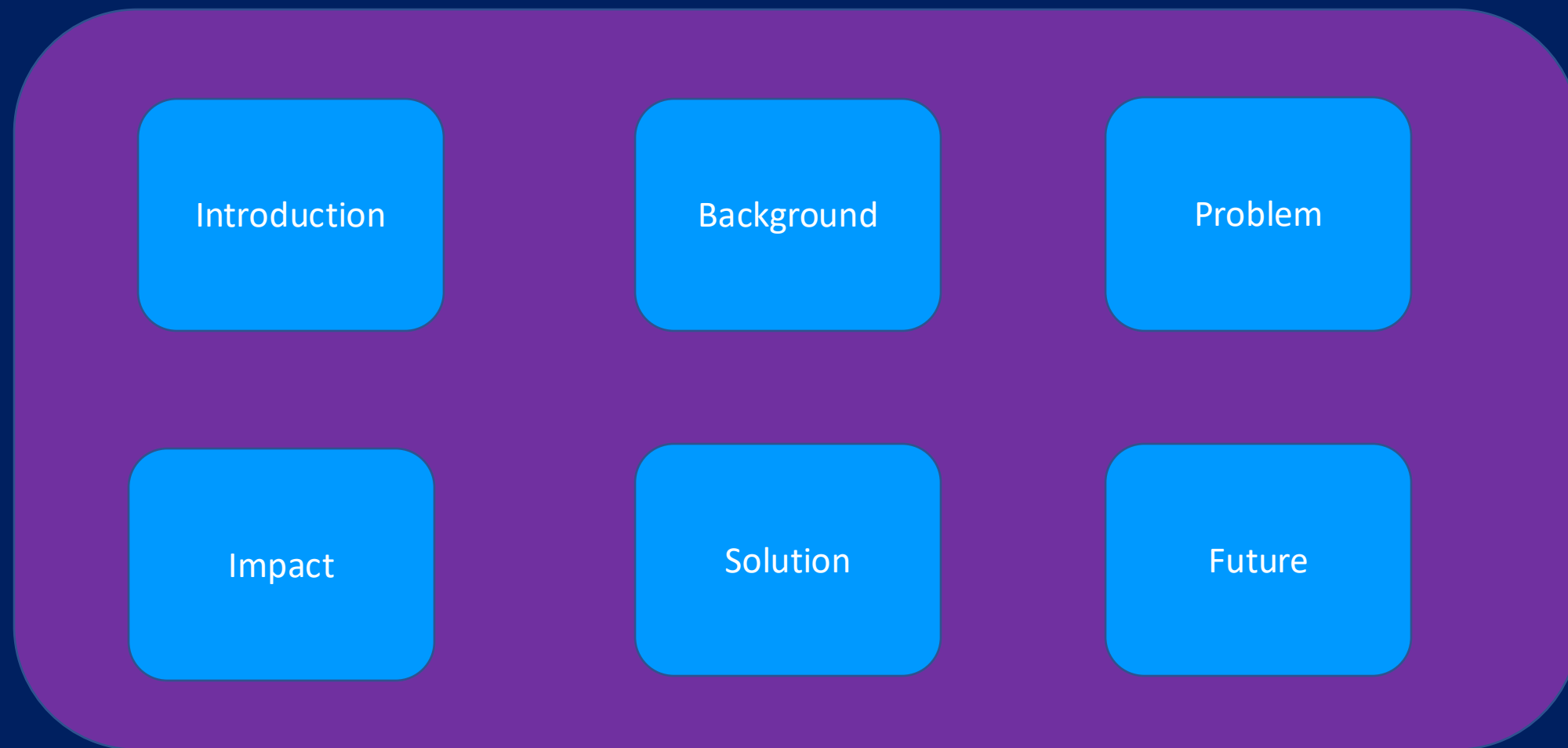
public final class Encryptor
{
    private static final String ALGORITHM = "DESede";
    private static final byte[] KEY = { 98, 105, 120, 111, 108, 111, 110, 95, 115, 111, 102, 116, 119, 97, 114, 101, 50, 48, 48 };
    private static final String TRANSFORMATION = "DESede/ECB/PKCS5Padding";

    public static String bytesToHex(byte[] paramArrayOfByte)
    {
        StringBuilder localStringBuilder = new StringBuilder(2 * paramArrayOfByte.length);
        for (int i = 0; i++)
        {
            if (i >= paramArrayOfByte.length) {
                return localStringBuilder.toString();
            }
            Object[] arrayOfObject = new Object[1];
            arrayOfObject[0] = Byte.valueOf(paramArrayOfByte[i]);
            localStringBuilder.append(String.format("%02X", arrayOfObject));
        }
    }

    public static byte[] decrypt(byte[] paramArrayOfByte)
    {
        try
        {
            // ...
        }
    }
}
```

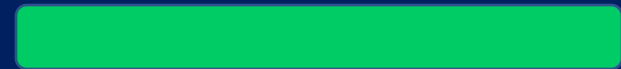
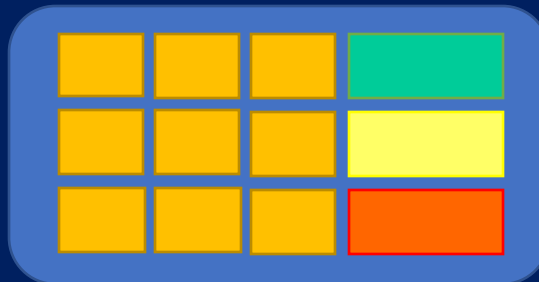
bixolon_software20140121



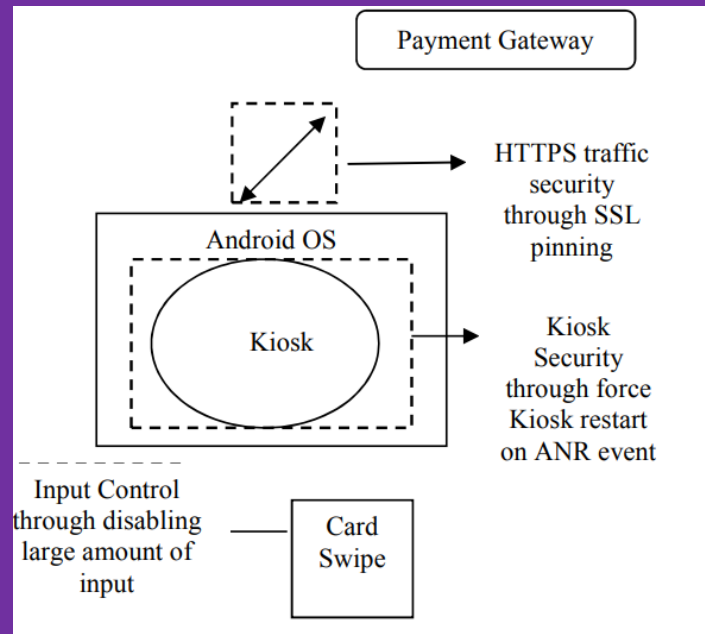


Solution

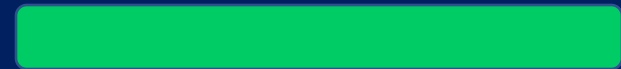
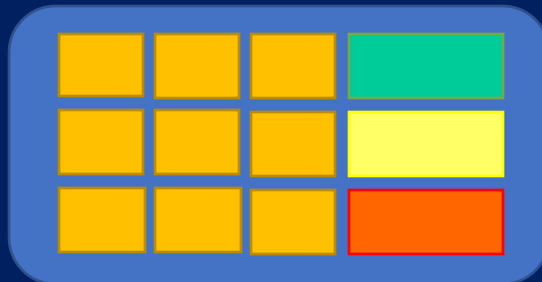
- ANR Event handling
- Anti malwares
- SSL Pinning with API Call Encryption
- Source Code Obfuscation



ANR Event handling



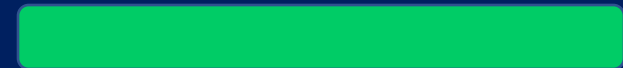
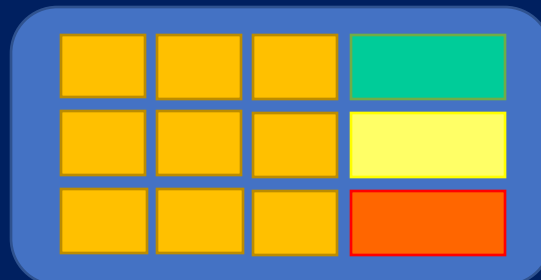
<http://ieeexplore.ieee.org/stamp/stamp.jsp?tp=&arnumber=8320167&isnumber=8320149>



Anti malwares

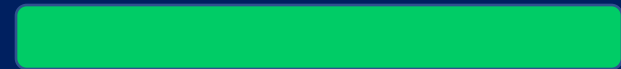
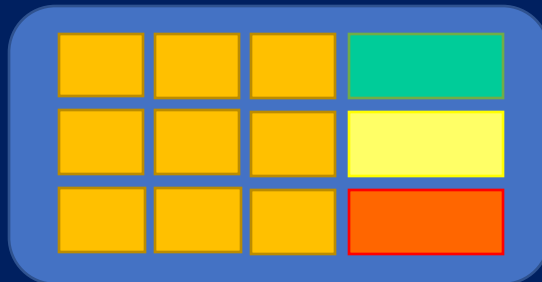
Android: September 2018				
	Producer	Certified	Protection	Usability
		✓	✓	✓
	TREND MICRO Mobile Security 9.5		6	6
	WeSecure 1.4		6	6
	SOPHOS Mobile Security 8.5		6	6
	Norton Mobile Security 4.3		6	6
	McAfee Mobile Security 5.0		6	6
	KASPERSKY Internet Security 11.17		6	6
	GDATA Internet Security 26.4		6	6
	Bitdefender Mobile Security 3.3		6	6
	AVG AntiVirus Free 6.10		6	6
	avast Mobile Security 6.11		6	6

<https://www.av-test.org/en/antivirus/mobile-devices/>



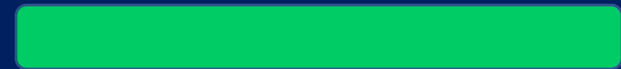
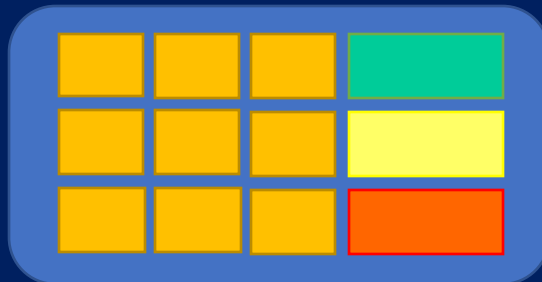
SSL Pinning with API Call Encryption

- Restrict an app's trusted CAs to a small set known to be used by the app's servers
- API Calls encryption with AES provides additional layer of security



Source Code Obfuscation

- Obfuscation is the deliberate act of creating source or machine code that is difficult for humans to understand. Like obfuscation in natural language
- Proguard
- DexGuard



Introduction

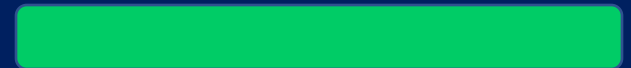
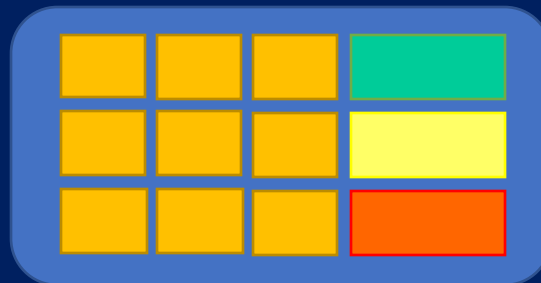
Background

Problem

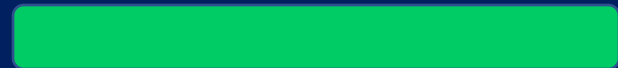
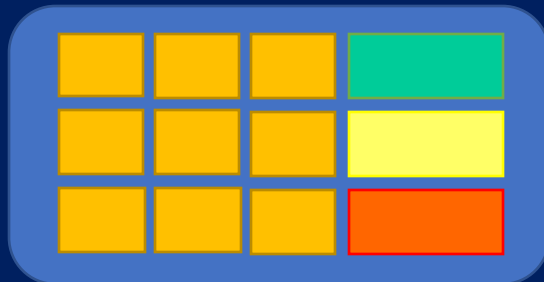
Impact

Solution

Future

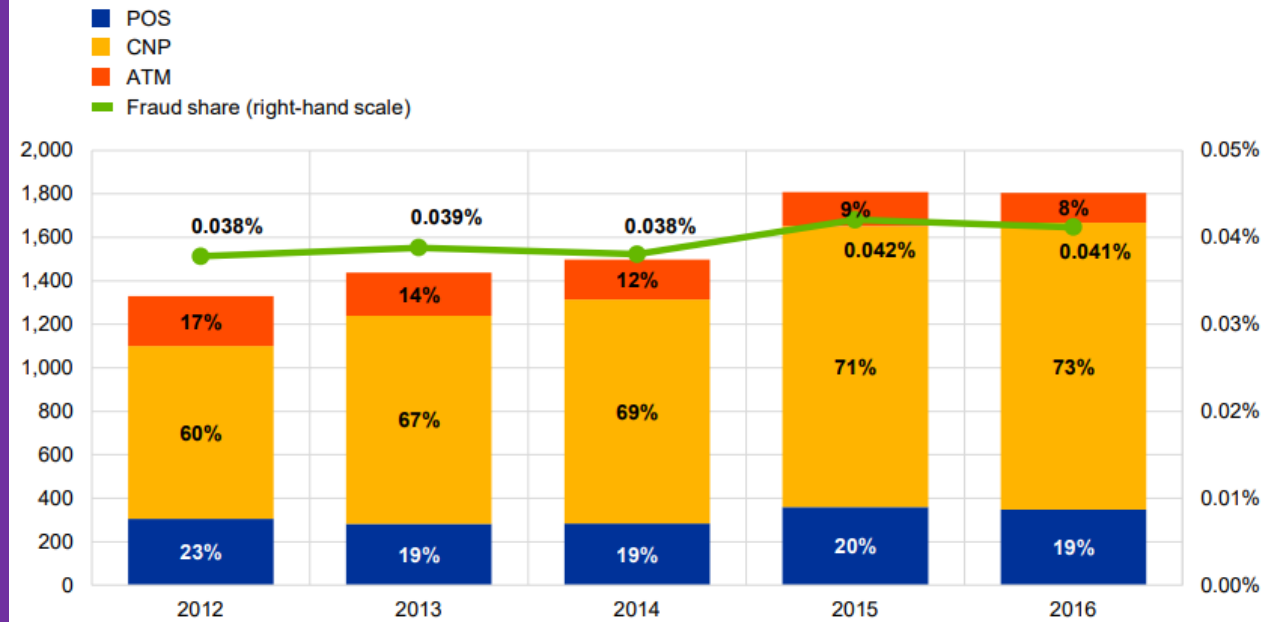


There is always light at the end of the tunnel

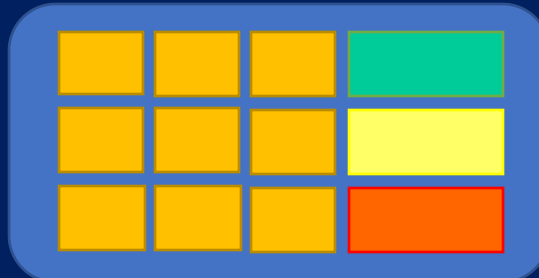


Evolution of the total value of card fraud using cards issued within SEPA

left-hand scale: total value (EUR millions); right-hand scale: value of fraud as share of value of transaction (%)

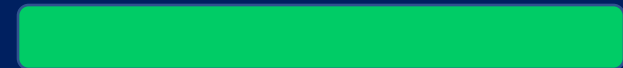
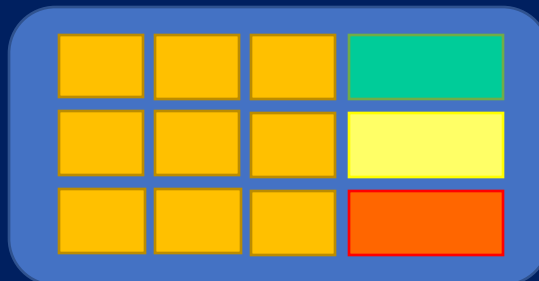
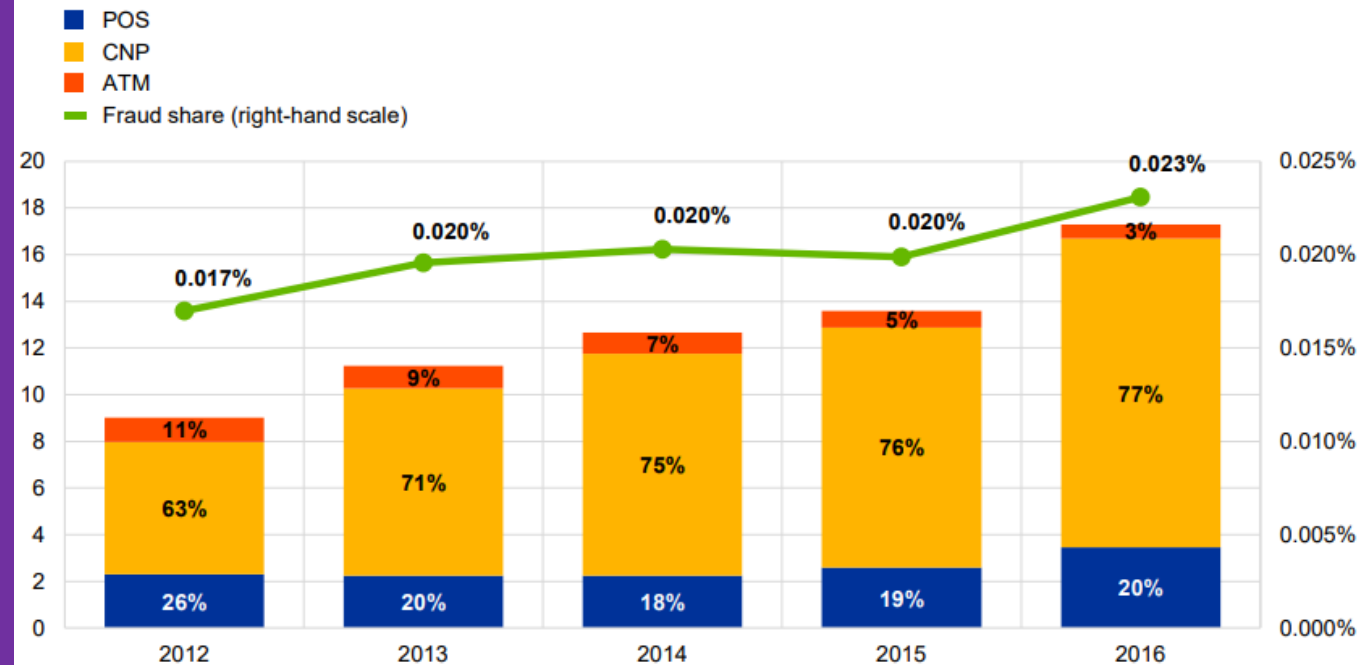


Source: All reporting CPSs.



Evolution of the total volume of card fraud using cards issued within SEPA

left-hand scale: total volume (million transactions); right-hand scale: volume of fraud as share of volume of transaction (%)



Thank You!

muhammad.m.yamin@ntnu.no

[linkedin.com/in/mudassaryamin](https://www.linkedin.com/in/mudassaryamin)

